

KapraDaily Security Remediation

Generated 2026-06-27

KapraDaily Security & Code-Quality Remediation

Branch: `refractor/forthCommit` **Date:** 2026-06-27

Context

A deep audit of the KapraDaily React Native e-commerce app surfaced critical secret exposure, insecure local storage of auth tokens and PII, and pervasive logging of sensitive data, plus several medium/low code-quality and injection risks. This document summarizes the findings and the remediation implemented across four prioritized phases (P0 → P3).

The app's network layer was otherwise sound going in: HTTPS enforced everywhere, ATS configured correctly on iOS, the Razorpay `keyId` fetched from the backend (not hardcoded), and automatic token refresh already implemented.

Findings Summary (verified against the repo)

#	Issue	Severity	Key Locations
1	Google Maps API key hardcoded in 5 files	Critical	<code>locationUtils.js</code> , <code>LocationFetchingScreen.js</code> , <code>AddLocationScreen.js</code> , <code>LocationFetchingNewScreen.js</code> (×2), <code>AndroidManifest.xml</code>
2	Firebase configs committed with API keys	Critical	<code>ios/GoogleService-Info.plist</code> , <code>android/app/google-services.json</code>
3	Release keystore password <code>123456</code> committed	Critical	<code>android/gradle.properties</code>
4	Auth tokens in plaintext AsyncStorage, no Keychain anywhere	High	<code>tokenService.js</code> , <code>LoginPwdScreen.js</code> , <code>OtpScreen.js</code> , <code>RegistrationScreen.js</code>
5	PII (custId, phone, email, address) in plaintext AsyncStorage	High	<code>appContext.js</code> , <code>CartContext.js</code>
6	Hardcoded test JWT branch + identity-confusion fallback (<code>return 3</code>)	Medium→High	<code>cartService.js</code>
7	~286 <code>console.log</code> calls; many dump payment payloads, tokens, addresses, full API responses	High	<code>CheckoutScreen.js</code> , <code>paymentService.js</code> , <code>CartContext.js</code> , <code>networkUtils.js</code> , <code>OtpScreen.js</code> , etc.
8	Open redirect — <code>Linking.openURL</code> on server-controlled URLs, no scheme validation	High	<code>home/HomeScreen.js</code> , <code>useHomePopup.js</code> , <code>OrderTrackingScreen.js</code> , <code>AppUpdateModal.js</code>
9	Unsanitized <code>RenderHtml</code> rendering backend HTML	High	<code>LegalContentScreen.js</code> , <code>VoucherBottomSheet.js</code> , <code>UdenTicketModal.js</code>
10	<code>.gitignore</code> missing rules for secret files	High	<code>.gitignore</code>

#	Issue	Severity	Key Locations
11	Missing <code>.catch()</code> on promise chains	Medium	<code>TicketLandingScreen.js</code>
12	Input validation gaps (email/OTP format)	Medium	<code>validation.js</code>
13	<code>Math.random()</code> used as a FlatList key	Low	<code>ProductListScreen.js</code>
14	Geocoder result accessed without null guard	Low	<code>locationUtils.js</code>

Phase P0 — Secret Exposure

Repo changes implemented:

1. Replaced the 5 hardcoded Google Maps key literals in JS with an import from a new, **gitignored** `src/globals/secrets.js`, templated by a tracked `src/globals/secrets.example.js`.
2. Converted the Android manifest's Maps key to a Gradle `manifestPlaceholder` (`_${GOOGLE_MAPS_API_KEY}`), wired through `android/app/build.gradle` via `project.findProperty('GOOGLE_MAPS_API_KEY')`.
3. Stripped the signing password/alias out of the tracked `android/gradle.properties`; relocated them to the per-developer `~/.gradle/gradle.properties` (never committed), with a tracked `android/gradle.properties.example` documenting the required keys.
4. Updated `.gitignore` to cover `.env*` and `secrets.js`. Deliberately **kept** the Firebase config files (`google-services.json`, `GoogleService-Info.plist`) tracked — these are client identifiers shipped inside every app binary regardless of git status; they're protected by GCP API-key restrictions and Firebase Security Rules, not by secrecy. Gitignoring them would only break clones/CI for no real security gain.

Still required from the user (cannot be fixed in code):

- Rotate/revoke the exposed Google Maps key in Google Cloud Console; restrict it by Android package + SHA-1 and to the Geocoding/Maps APIs only.
- Rotate the two exposed Firebase API keys; confirm Firestore/Storage rules require authentication.
- Change the release keystore password (was `123456`); if the key itself is considered compromised, a new upload key must be registered with Play Console.
- **Decide on git history:** the old secret values remain recoverable from git history even after rotation. Two options were presented and the decision was deferred:
 - a. accept residual exposure since rotated keys are worthless to an attacker, or

- b. scrub history with `git filter-repo` /BFG and force-push (disruptive — requires every collaborator to re-clone and CI to be reconfigured). **Not executed.**

Phase P1 — Sensitive-Data Logging

- Added `src/utils/logger.js` : a centralized logger where `log` / `info` are no-ops in production (`__DEV__` check) and `warn` / `error` are kept but **deep-redact** any object key matching patterns like `token` , `password` , `signature` , `razorpay` , `otp` , `phone` , `email` , `custId` , `address` , `pincode` , `apiKey` , etc.
- Added a Babel plugin (`babel-plugin-transform-remove-console`) wired into `babel.config.js` so that **all** `console.*` calls are stripped from production bundles (keeping `warn` / `error`), as defense-in-depth beyond the logger.
- Converted explicit sensitive logs across ~14 files to the new logger, notably:
 - `networkUtils.js` — token-refresh response is no longer logged at all (only HTTP status); refresh-failure logs status/message instead of raw error data.
 - `paymentService.js` — removed the full Razorpay verification payload log.
 - `cartService.js` — removed coupon/gift-card payload dumps.
 - `CheckoutScreen.js` — order payloads, Razorpay create/verify responses.
 - `OtpScreen.js` — phone numbers are now masked (`....1234`) in dev logs; OTP/login responses are no longer logged in full.
 - `CartContext.js` , `appContext.js` — address and profile dumps.
 - `OneSignalService.ts` — push token and subscription ID now log `present` / `NOT FOUND` instead of the raw value.
- Verified behavior directly: a dev build keeps all logs; a production build (`NODE_ENV=production`) strips `console.log` while preserving `console.warn` / `error` .

Phase P2 — Secure Storage & Injection Hardening

Storage seam (no new native dependency added — by design):

- Added `src/utils/secureStore.js` : a single interface (`getItem` / `setItem` / `removeItem` / `multiSet` / `multiRemove`) currently backed by `AsyncStorage`. `src/api/tokenService.js` now routes through it exclusively.
- Refactored `LoginPwdScreen.js` , `OtpScreen.js` , and `RegistrationScreen.js` , which each had their own duplicated inline `setTokens` / `AsyncStorage.multiSet` implementation, to call the shared `tokenService.setTokens` instead — no behavior change, single source of truth.
- This means swapping `AsyncStorage` for `react-native-keychain` (tokens) and/or `react-native-encrypted-storage` (PII) later is a one-file change with no call-site changes required.

Removed a real bug, not just a logging issue:

- `cartService.js` 's `getUserId()` had a hardcoded test JWT check, and — more seriously — fell back to a **hardcoded user ID of 3** whenever token parsing failed. Since this ID is used directly in cart API paths (`cart/${idToUse}/applycoupon`, etc.), a parse failure could silently operate on another user's cart. Replaced with `src/utils/jwt.js`, a small dependency-free JWT decoder that fails to `null` instead of a magic number, and removed the test-token backdoor entirely.

Open-redirect / injection hardening:

- Added `src/utils/safeUrl.js`: `isSafeUrl()` allows only `http:`, `https:`, `tel:`, `mailto:` schemes; `openExternalUrl()` validates and opens, rejecting `javascript:`, `data:`, `file:`, `intent:`, etc. with a warning instead of executing them.
- Wrapped every server-controlled `Linking.openURL` call with it: home banner taps, home popup links, order invoice download URL, and the in-app-update redirect URL.
- Added `src/components/SafeRenderHtml.js`: a drop-in wrapper around `react-native-render-html` that strips `<script>`, `<iframe>`, `<object>`, `<embed>`, `<form>`, `<input>`, `<button>`, `<textarea>`, `<style>`, `<link>`, `<meta>`, `<base>`, and routes every anchor tap through `openExternalUrl` instead of handing the href straight to `Linking`. Swapped in across all three backend-HTML render sites: `LegalContentScreen.js`, `VoucherBottomSheet.js`, `UdenTicketModal.js`.

Phase P3 — Validation, Error Handling, Hygiene

- `src/utils/validation.js`: added `validateEmail`, `validateOtp(otp, length)`, and `maskPhoneNumber` for use in screens that previously had no format validation.
- `src/utils/locationUtils.js`: null-guarded the geocoder result (`geo?.results?.[0]`) so an empty geocoding response rejects cleanly instead of throwing a raw property-access crash.
- `src/screens/ProductListScreen.js`: replaced a `Math.random()` FlatList `keyExtractor` fallback (causes unnecessary remounts) with a stable `product-${index}` fallback.
- `src/screens/ticketLandingScreen/TicketLandingScreen.js`: added `.catch()` handlers to four previously-unguarded promise chains (`getDashboardDataApi`, `getVouchersApi`, `getMyVouchersApi`, and the `Promise.all` voucher-claim flow), routed through the new logger.
- **Dependency audit**: `axios` is already current (1.13.4 — the original audit's "outdated 1.13.2" note was stale by the time of verification). Scoped `npm audit` to production dependencies only; remaining findings (`ws`, `shell-quote`, `yaml`) are all Node-side build/tooling transitives — notably the `ws` DoS is under `@microsoft/signalr`, which never runs its Node `ws` implementation on a React Native device (RN provides a native WebSocket). Left the lockfile untouched rather than risk a forced, breaking dependency bump as part of a security-focused change.

Files Changed

New files:

- `src/utils/logger.js` — redacting, production-safe logger
- `src/utils/secureStore.js` — single storage seam for sensitive data
- `src/utils/jwt.js` — dependency-free JWT payload decoder
- `src/utils/safeUrl.js` — URL-scheme allowlist + safe `Linking.openURL` wrapper
- `src/components/SafeRenderHtml.js` — hardened `RenderHtml` wrapper
- `src/globals/secrets.example.js` — template for the gitignored secrets file
- `android/gradle.properties.example` — template for per-developer signing/Maps secrets

Modified (selected, grouped by concern):

- Secrets: `.gitignore`, `android/gradle.properties`, `android/app/build.gradle`, `android/app/src/main/AndroidManifest.xml`, `src/utils/locationUtils.js`, `src/screens/LocationFetchingScreen.js`, `src/screens/AddLocationScreen.js`, `src/screens/LocationFetchingNewScreen.js`
- Logging: `babel.config.js`, `package.json` (added `babel-plugin-transform-remove-console`), `src/api/networkUtils.js`, `src/api/paymentService.js`, `src/api/cartService.js`, `src/screens/CheckoutScreen.js`, `src/screens/OtpScreen.js`, `src/screens/LoginScreen.js`, `src/screens/LoginPwdScreen.js`, `src/screens/RegistrationScreen.js`, `src/screens/MyOrdersScreen.js`, `src/screens/OrderSuccessScreen.js`, `src/context/CartContext.js`, `src/context/appContext.js`, `src/services/OneSignalService.ts`
- Storage: `src/api/tokenService.js`, `src/screens/LoginPwdScreen.js`, `src/screens/OtpScreen.js`, `src/screens/RegistrationScreen.js`
- Injection: `src/screens/home/HomeScreen.js`, `src/screens/home/hooks/useHomePopup.js`, `src/screens/OrderTrackingScreen.js`, `src/components/AppUpdateModal.js`, `src/screens/LegalContentScreen.js`, `src/screens/ticketLandingScreen/components/VoucherBottomSheet.js`, `src/screens/ticketLandingScreen/components/UdenTicketModal.js`
- Validation/hygiene: `src/utils/validation.js`, `src/screens/ProductListScreen.js`, `src/screens/ticketLandingScreen/TicketLandingScreen.js`

Verification Performed

- All 34 edited/added JS/TS files were parsed with the project's actual Babel preset (`@react-native/babel-preset`) — zero syntax errors.
- Confirmed via `git grep` that no `AIzaSy...` key or the `123456` signing password remains in any tracked file outside the (now gitignored) `secrets.js`.
- Confirmed `babel.config.js` behavior directly: a dev-mode transform keeps `console.log/warn/error`; a `NODE_ENV=production` transform strips `console.log` while preserving `console.warn` and `console.error`.
- Confirmed `secrets.js` is git-ignored (`git check-ignore`) while `secrets.example.js` and `gradle.properties.example` are tracked as new files.

Not Yet Done / Requires Follow-Up

- Provider-side key rotation (Maps, Firebase, keystore password) — must be done by the project owner outside the repo.
- Git-history scrub decision — deferred per explicit user instruction.
- Swapping `secureStore.js`'s AsyncStorage backend for `react-native-keychain` / `react-native-encrypted-storage` — deferred per explicit user instruction (no new native dependency added without approval); the seam is in place for a one-file change.
- No emulator/device build or manual QA pass (login → checkout → logout) has been run against these changes yet.